

Clinic Network and Security Design

Network design proposal for a healthcare clinic

Overview

This project is based on a report I wrote for a university module on Cyber Security and Networks. The task was to design the network and cyber security setup for a new branch of a private healthcare clinic. I planned how the network would be split into subnets, which devices it would need, and how the clinic could keep patient data safe.

Disclaimer

For this portfolio version I changed the clinic name, location, host numbers and IP ranges. The company is fictional. The design approach and security choices are the ones I made in my original report.

Scenario

Northbrook Health is a fictional private clinic opening a new branch in Exeter. The branch needs to store patient records, medical images and staff information. It also hosts a web app where patients can book appointments and view prescriptions, and where staff can manage patient information.

The clinic has these servers:

- File storage for medical files such as scans
- A database server for patient and staff records
- A log server to record activity on medical records
- A web server for the booking web app
- A backup server

The clinic wanted a network that is secure, reliable, low cost and able to grow. It also plans to hire more GPs in the next two years.

Area	Hosts needed
GP Team	90
Urgent Care	45
Physiotherapy	28
Admin Staff	10
Servers	5

Address type	Range
Public (to ISP)	203.0.113.0/30
Private (inside)	172.16.8.0/22

Network Architecture

Subnetting

I split the private range into one subnet for each department and one for the servers. I started with the largest group and worked down to the smallest. This way each subnet is only as big as it needs to be, and no addresses overlap.

Network	Network Address	Mask	Usable Range	Broadcast
GP Team	172.16.8.0	/25	172.16.8.1 to 172.16.8.126	172.16.8.127
Urgent Care	172.16.8.128	/26	172.16.8.129 to 172.16.8.190	172.16.8.191
Physiotherapy	172.16.8.192	/27	172.16.8.193 to 172.16.8.222	172.16.8.223
Admin Staff	172.16.8.224	/28	172.16.8.225 to 172.16.8.238	172.16.8.239
Servers	172.16.8.240	/29	172.16.8.241 to 172.16.8.246	172.16.8.247
ISP Link	203.0.113.0	/30	203.0.113.1 to 203.0.113.2	203.0.113.3

The GP team needs 90 hosts and the /25 subnet gives 126 usable addresses. That leaves 36 spare for new staff. The rest of the /22 range, from 172.16.8.248 to 172.16.11.255, is not used yet, so new subnets can be added later.

Splitting the network into subnets helps in three ways:

- It cuts down traffic, because devices only talk to others in their own subnet unless they need to go further.
- It improves security, because each department is kept apart, which makes it harder for someone to reach the servers.
- It makes growth easier, because each area can be resized or added to without changing the others.

Devices

- Router to connect the clinic to the internet using the public address.
- Firewall to control traffic coming in and going out.
- Switches to connect the devices in each department.
- Wireless access points to give Wi-Fi to staff and patients.

These are standard devices, so they are low cost, reliable and easy to replace.

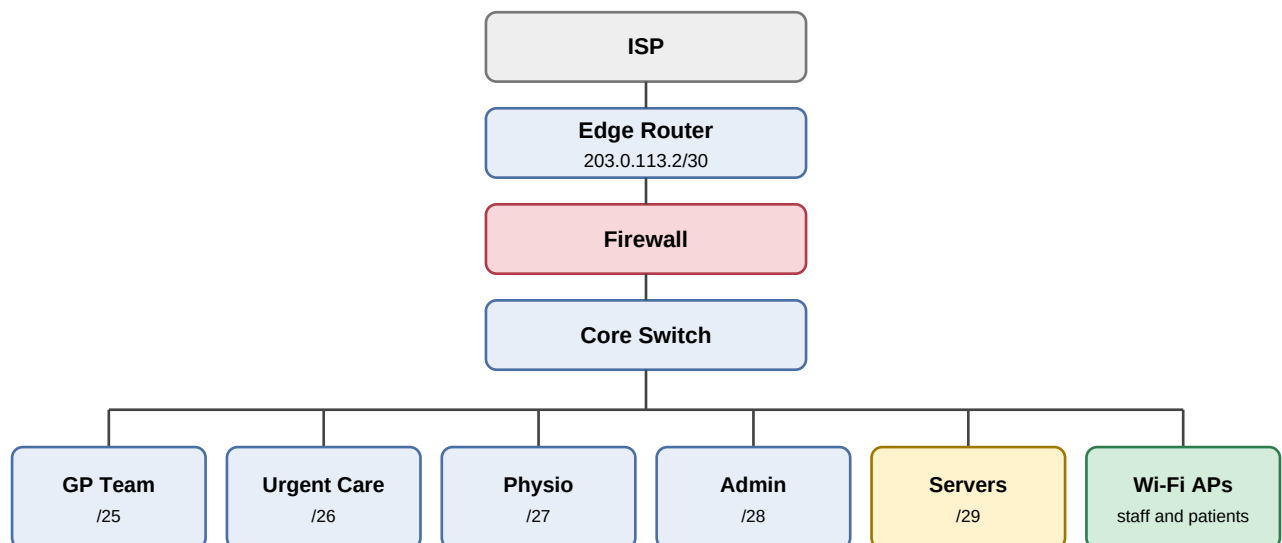


Figure 1. Network layout from my original design

Security Architecture

I chose six main security measures to protect patient and staff data.

Measure	What it does	Why I chose it
Firewall	Sits between the clinic and the internet and blocks traffic that is not allowed.	First line of defence against attackers and malware, while still letting staff and patients use the web app.
VPN	Creates an encrypted connection for staff working remotely.	Data sent over the internet cannot be read if someone intercepts it.
Antivirus	Runs on every device and is kept up to date.	Protects against viruses, spyware and ransomware that could steal or lock data.
Role-based access control	Staff can only reach the data and systems their job needs.	Lowers the risk of data being misused, whether by mistake or on purpose.
Daily backups	Copies of the database and file storage kept on site and off site.	The clinic can recover quickly after hardware failure, mistakes or a ransomware attack.
Network monitoring	Watches network activity in real time and alerts staff to anything suspicious.	Problems can be found and dealt with early before they grow.

Together these give several layers of protection. If one measure fails, another can still stop or spot the attack. The VPN and access control keep data private, and the backups mean the clinic can recover quickly.

Staff Training and the Law

Security tools only work if staff use them properly. Staff should have regular training on using the VPN safely and spotting phishing emails. The design also helps the clinic meet the UK Data Protection Act 2018 and UK GDPR, which require patient data to be kept secure.

Open Issues

- **Budget.** If the budget is tight, some security measures may need to be done before others.
- **Growth.** As the GP team grows, the clinic may need more switches, access points or bandwidth.
- **Training.** Staff training has to happen regularly, not just once.

What I Would Change Now

Since writing the original report I have learned more through my studies and the TryHackMe SOC Level 1 path. Looking back, there are some gaps in my design. This section is extra and was not part of my original report.

- **Put the web server in a DMZ.** The web server faces the internet, so it is the most likely to be attacked. In my original design it sat with the database. If it was hacked, the attacker would be right next to the patient records. A DMZ keeps it separate.
- **Use VLANs.** The brief said staff from one department could sit anywhere in the building. VLANs let me group devices by department even if they are on different switches.
- **Give patients their own Wi-Fi.** Patient Wi-Fi should only reach the internet, never the staff or server networks.
- **Add firewall rules between subnets.** For example, only the web server should talk to the database, and only on the port it needs.
- **Add multi-factor authentication.** This would protect staff logins and the VPN even if a password is stolen.

- **Encrypt stored data.** The database and file storage should be encrypted, not just the data sent over the VPN.
- **Send logs to a SIEM.** The clinic already has a log server. Sending logs from the firewall, servers and computers to a SIEM would let a SOC team spot attacks, which links to what I am learning now.

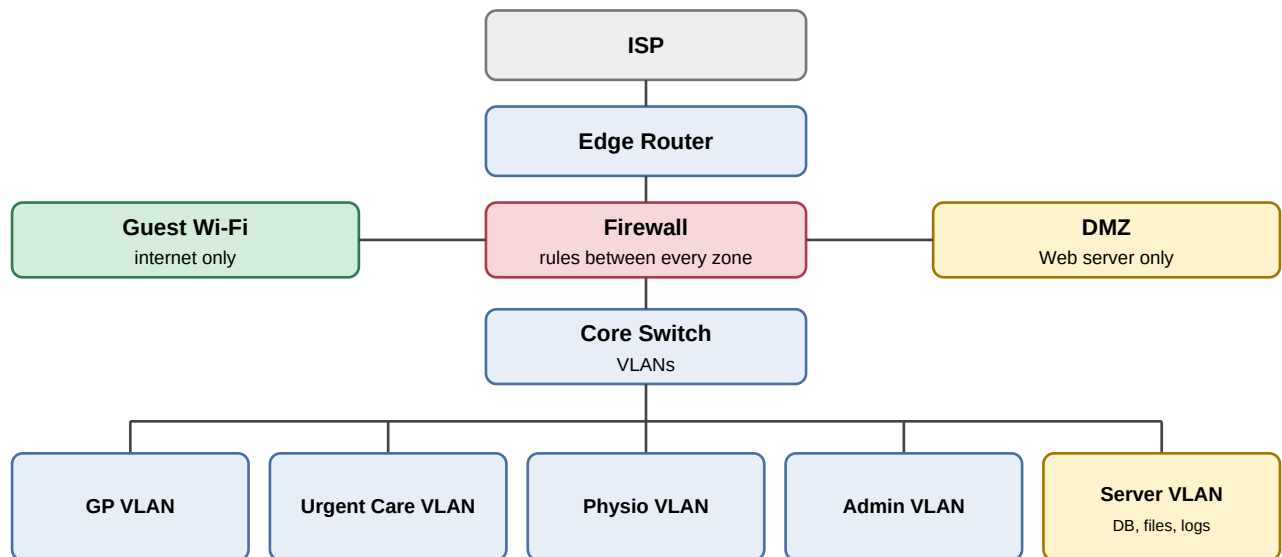


Figure 2. How I would improve the layout now

Conclusion

This project shows how I planned a network for a healthcare clinic, from subnetting the address range to choosing security measures that protect patient data. Looking back at it also shows how my understanding has grown, especially around separating systems that face the internet from the ones that hold sensitive data.